A better solution is for the application to request the scopes that it requires, and then the API can ask the user if they consent. This is the approach taken by the *OAuth2 delegated authorization protocol*, as shown in figure 7.4. Because an organization may have many APIs, OAuth introduces the notion of an Authorization Server (AS), which acts as a central service for managing user authentication and consent and issuing tokens. As you'll see later in this chapter, this centralization provides significant advantages even if your API has no third-party clients, which is one reason why OAuth2 has become so popular as a standard for API security. The tokens that an application uses to access an API are known as *access tokens* in OAuth2, to distinguish them from other sorts of tokens that you'll learn about later in this chapter.

> **DEFINITION** An ***access token*** is a token issued by an OAuth2 authorization server to allow a client to access an API.